

MAPEO DETALLADO: PREGUNTAS ENCUESTA → REQUISITOS NORMATIVOS

Matriz de Trazabilidad Completa (NIST CSF 2.0, ENS, NIS2, GDPR, ISO 27001)

Versión: 2.0 | **Fecha:** Enero 2026 | **Objetivo:** Demostrar alineación regulatoria

CÓMO USAR ESTA MATRIZ

Para cada pregunta de la encuesta ACET:

1. Identificar en columna B el ID de pregunta (Ej. P1.1.1)
2. Leer pregunta en columna C
3. Verificar en columnas D-H qué marcos normativos aplican (✓ = Aplica)
4. Consultar columna I para artículos/cláusulas específicas
5. Usar columna J para evidencia (documento a auditar)

Uso típico: Auditor regulador pregunta "¿Cómo cumple Art. 18 NIS2?" → Buscar NIS2 en tabla → Encontrar 5 preguntas asociadas → Mostrar evidencia.

MATRIZ COMPLETA: 60+ PREGUNTAS × 5 MARCOS

DOMINIO: GOBIERNO (GV)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P1.1.1	¿Existe Política Ciberseguridad formalizada?	✓ GV-1	✓ A.5	✓ Art.18.1	✓ Art.32(1)	✓ 5.1	NIST GV-1; ENS A.5.1; NIS2 Art.18(1) (a); GDPR Art.32; ISO 5.1	Política documento v2025, Aprobado Junta acta
P1.1.2	¿Designación formal CISO?	✓ GV-2	✓ A.6	✓ Art.18.3	✓ Art.37	✓ 5.3	NIST GV-2; ENS A.6.1; NIS2 Art.18(3) (a); GDPR Art.37; ISO 5.3	Organigrama actual, contrato CISO
P1.1.3	¿Comité riesgos cibernéticos (frecuencia)?	✓ GV-3	✓ A.7	✓ Art.18.2	✓ Art.32(3)	✓ 5.2	NIST GV-3; ENS A.7; NIS2 Art.18(2); GDPR Art.32(3); ISO 5.2	Actas reuniones últimos 12 meses
P1.1.4	¿Registro riesgos actualizado?	✓ GV-4	✓ A.8	✓ Art.19	✓ Art.32	✓ 6.1.2	NIST GV-4; ENS A.8; NIS2 Art.19; GDPR Art.32; ISO 6.1.2	Registro riesgos fecha última actualización
P1.2.1	¿Evaluaciones riesgos formales (anual+) ?	✓ GV-5	✓ A.9	✓ Art.19	✓ Art.32(3)	✓ 6.1.3	NIST GV-5; ENS A.9; NIS2 Art.19 (evaluación riesgos); ISO 6.1.3	Informes evaluación riesgos 2024, 2025

P1.2.2	¿Estrategia mitigación riesgos documentada?	✓ GV-6	✓ A.10	✓ Art.20	✓ Art.32	✓ 6.2	NIST GV-6; ENS A.10; NIS2 Art.20 (plan medidas); ISO 6.2	Plan medidas, roadmap 12 meses
---------------	---	--------	--------	----------	----------	-------	--	--------------------------------

DOMINIO: IDENTIFICAR (ID)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P2.1.1	¿CMDB con >90% cobertura activos?	✓ ID-1	✓ B.1	✓ Art.21	✓ Art.32	✓ 7.2	NIST ID-1; ENS B.1; NIS2 Art.21 (gestión inventario); ISO 7.2	Export CMDB, análisis cobertura
P2.1.2	¿Clasificación datos por sensibilidad?	✓ ID-2	✓ B.2	✓ Art.21	✓ Art.32(1) (b)	✓ 7.1	NIST ID-2; ENS B.2; NIS2 Art.21; GDPR Art.32(1) (b); ISO 7.1	Matriz clasificación, DLP report
P2.1.3	¿Flujos datos documentados?	✓ ID-3	✓ B.3	✓ Art.21	✓ Art.30	✓ 7.3	NIST ID-3; ENS B.3; NIS2 Art.21; GDPR Art.30 (ROPA); ISO 7.3	Diagrama flujos datos, ROPA
P2.2.1	¿Evaluaciones vulnerabilidades (mensual+)?	✓ ID-4	✓ B.4	✓ Art.21	✓ Art.32	✓ 8.1.1	NIST ID-4; ENS B.4; NIS2 Art.21; ISO 8.1.1	Reports escaneo Nessus/Qualys últimos 3 meses
P2.2.2	¿Penetration testing (anual+)?	✓ ID-5	✓ B.5	✓ Art.22	✓ Art.32	✓ 8.1.3	NIST ID-5; ENS B.5; NIS2 Art.22 (pruebas seguridad); ISO 8.1.3	Informe pentest externo 2024/2025

P2.3.1	¿Amenazas identificadas y documentadas?	✓ ID-6	✓ B.6	✓ Art.21	✓ Art.30	✓ 6.1.1	NIST ID-6; ENS B.6; NIS2 Art.21; GDPR Art.30; ISO 6.1.1	Threat model, STRIDE/ CAPEC
---------------	---	--------	-------	----------	----------	---------	---	-----------------------------

DOMINIO: PROTEGER (PR)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P3.1.1	¿MFA implementado (>85% críticos)?	✓ PR-1	✓ C.1	✓ Art.20	✓ Art.32	✓ 8.2.4	NIST PR-1; ENS C.1; NIS2 Art.20 (autenticación); GDPR Art.32; ISO 8.2.4	AD report MFA habilitado, screenshot
P3.1.2	¿Cifrado en tránsito (TLS 1.2+)?	✓ PR-2	✓ C.2	✓ Art.20	✓ Art.32(1) (b)	✓ 8.2.3	NIST PR-2; ENS C.2; NIS2 Art.20; GDPR Art.32(1) (b); ISO 8.2.3	SSL scan report, configuración TLS
P3.1.3	¿Cifrado en reposo datos sensibles?	✓ PR-3	✓ C.3	✓ Art.20	✓ Art.32(1) (b)	✓ 8.2.3	NIST PR-3; ENS C.3; NIS2 Art.20; GDPR Art.32(1) (b); ISO 8.2.3	Configuración encryption DB, backups
P3.2.1	¿Gestión accesos basada roles (RBAC)?	✓ PR-4	✓ C.4	✓ Art.20	✓ Art.32	✓ 8.2.2	NIST PR-4; ENS C.4; NIS2 Art.20; GDPR Art.32; ISO 8.2.2	IAM policy, AD roles audit
P3.3.1	¿Capacitación seguridad anual (>95%)?	✓ PR-5	✓ C.5	✓ Art.24	✓ Art.32(2) (c)	✓ 8.3.2	NIST PR-5; ENS C.5; NIS2 Art.24 (concienciación); GDPR Art.32(2) (c); ISO 8.3.2	LMS report completación, certificados

P3.4.1	¿Segmentación red (demilitarized)?	✓ PR-6	✓ C.6	✓ Art.20	✓ Art.32	✓ 8.2.1	NIST PR-6; ENS C.6; NIS2 Art.20; ISO 8.2.1	Diagrama red, firewall rules
---------------	------------------------------------	--------	-------	----------	----------	---------	--	------------------------------

DOMINIO: DETECTAR (DE)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P4.1.1	¿SIEM cobertura (>85% sistemas)?	✓ DE-1	✓ D.1	✓ Art.21	✓ Art.32	✓ 8.4.1	NIST DE-1; ENS D.1; NIS2 Art.21 (detección); ISO 8.4.1	SIEM console coverage report
P4.1.2	¿Logs centralizados (mínimo 90 días)?	✓ DE-2	✓ D.2	✓ Art.21	✓ Art.32	✓ 8.4.2	NIST DE-2; ENS D.2; NIS2 Art.21; ISO 8.4.2	SIEM storage config, retention policy
P4.1.3	¿Correlación eventos (ML/análisis)?	✓ DE-3	✓ D.3	✓ Art.21	✓ Art.32	✓ 8.4.3	NIST DE-3; ENS D.3; NIS2 Art.21; ISO 8.4.3	SIEM rules engine, correlation examples
P4.2.1	¿MTTD <2 horas (media detección)?	✓ DE-4	✓ D.4	✓ Art.21	✓ Art.32	✓ 8.4.4	NIST DE-4; ENS D.4; NIS2 Art.21; ISO 8.4.4	SIEM dashboard MTTD metric
P4.3.1	¿False Positive Rate <25%?	✓ DE-5	✓ D.5	✓ Art.21	✓ Art.32	✓ 8.4.5	NIST DE-5; ENS D.5; NIS2 Art.21; ISO 8.4.5	SOC metrics, FPR trend

DOMINIO: RESPONDER (RS)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P5.1.1	¿Plan respuesta incidentes (actualizado)?	✓ RS-1	✓ E.1	✓ Art.23	✓ Art.33	✓ 8.5.1	NIST RS-1; ENS E.1; NIS2 Art.23; GDPR Art.33; ISO 8.5.1	Documento plan incidentes v2025
P5.1.2	¿Simulacros anuales (mínimo 1)?	✓ RS-2	✓ E.2	✓ Art.23	✓ Art.33	✓ 8.5.2	NIST RS-2; ENS E.2; NIS2 Art.23; GDPR Art.33; ISO 8.5.2	Informe simulacro 2024/2025
P5.2.1	¿MTTR <4 horas (resolución)?	✓ RS-3	✓ E.3	✓ Art.23	✓ Art.33	✓ 8.5.3	NIST RS-3; ENS E.3; NIS2 Art.23; GDPR Art.33; ISO 8.5.3	Metrics SOC, dashboard MTTR
P5.3.1	¿Notificación breach <72h (GDPR)?	✓ RS-4	✓ E.4	✓ Art.24	✓ Art.33	✓ 8.5.4	NIST RS-4; ENS E.4; NIS2 Art.24; GDPR Art.33; ISO 8.5.4	Procedimiento notificación AEPD
P5.4.1	¿Análisis post-incidente (post-mortem)?	✓ RS-5	✓ E.5	✓ Art.23	✓ Art.33	✓ 8.5.5	NIST RS-5; ENS E.5; NIS2 Art.23; GDPR Art.33; ISO 8.5.5	Reports post-mortem incidentes 2024

DOMINIO: RECUPERAR (RC)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P6.1.1	¿Estrategia backups 3-2-1 implementada?	✓ RC-1	✓ F.1	✓ Art.20	✓ Art.32	✓ 8.3.4	NIST RC-1; ENS F.1; NIS2 Art.20; GDPR Art.32; ISO 8.3.4	Política backups, configuración
P6.1.2	¿RTO/RPO documentados por aplicación?	✓ RC-2	✓ F.2	✓ Art.20	✓ Art.32	✓ 8.3.5	NIST RC-2; ENS F.2; NIS2 Art.20; GDPR Art.32; ISO 8.3.5	Documento RTO/RPO business
P6.2.1	¿Pruebas restauración anuales?	✓ RC-3	✓ F.3	✓ Art.22	✓ Art.32	✓ 8.3.6	NIST RC-3; ENS F.3; NIS2 Art.22 (pruebas); GDPR Art.32; ISO 8.3.6	Reports pruebas restauración 2024
P6.3.1	¿Plan continuidad negocio (BCP) actual?	✓ RC-4	✓ F.4	✓ Art.20	✓ Art.32	✓ 8.3.3	NIST RC-4; ENS F.4; NIS2 Art.20; GDPR Art.32; ISO 8.3.3	Documento BCP v2025
P6.4.1	¿Segregación datos backup off-site?	✓ RC-5	✓ F.5	✓ Art.20	✓ Art.32(1) (b)	✓ 8.3.4	NIST RC-5; ENS F.5; NIS2 Art.20; GDPR Art.32(1) (b); ISO 8.3.4	Configuración backup geo-redundante

DOMINIO: VULNERABILIDADES (VA)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P7.1.1	¿Escaneos vulnerabilidades formales?	✓ VA-1	✓ B.4	✓ Art.21	✓ Art.32	✓ 8.1.1	NIST VA-1; ENS B.4; NIS2 Art.21; ISO 8.1.1	Reports Nessus/Qualys
P7.1.2	¿Severidad vulnerabilidades clasificada?	✓ VA-2	✓ B.5	✓ Art.21	✓ Art.32	✓ 8.1.2	NIST VA-2; ENS B.5; NIS2 Art.21; ISO 8.1.2	Matriz vulnerabilidades por CVSS
P7.1.3	¿CVE crítica sin parchear (Target: 0)?	✓ VA-3	✓ B.6	✓ Art.21	✓ Art.32	✓ 8.1.3	NIST VA-3; ENS B.6; NIS2 Art.21; ISO 8.1.3	Scan actual, análisis CVE
P7.2.1	¿SLA remediación por severidad?	✓ VA-4	✓ B.7	✓ Art.22	✓ Art.32	✓ 8.1.4	NIST VA-4; ENS B.7; NIS2 Art.22; ISO 8.1.4	Política SLA parcheo
P7.3.1	¿% Vulnerabilidades remediadas (90 días)?	✓ VA-5	✓ B.8	✓ Art.21	✓ Art.32	✓ 8.1.5	NIST VA-5; ENS B.8; NIS2 Art.21; ISO 8.1.5	Trend report remediación

DOMINIO: SIEM & MONITOREO (SIEM)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P8.1.1	¿SIEM integración fuentes (>85%)?	✓ DE-1	✓ D.1	✓ Art.21	✓ Art.32	✓ 8.4.1	NIST DE-1; ENS D.1; NIS2 Art.21; ISO 8.4.1	SIEM console, lista data sources
P8.1.2	¿Correlación eventos habilitada?	✓ DE-3	✓ D.3	✓ Art.21	✓ Art.32	✓ 8.4.3	NIST DE-3; ENS D.3; NIS2 Art.21; ISO 8.4.3	Configuración correlation engine
P8.2.1	✓ DE-4	✓ D.4	✓ Art.21	✓ Art.32	✓ 8.4.4	NIST DE-4; ENS D.4; NIS2 Art.21; ISO 8.4.4	MTTD dashboard, análisis	
P8.3.1	¿Tuning reglas (reducir FP)?	✓ DE-5	✓ D.5	✓ Art.21	✓ Art.32	✓ 8.4.5	NIST DE-5; ENS D.5; NIS2 Art.21; ISO 8.4.5	FPR trend, mejoras tuning
P8.4.1	¿Alert-to-Incident ratio (target 1:50)?	✓ DE-2	✓ D.2	✓ Art.21	✓ Art.32	✓ 8.4.2	NIST DE-2; ENS D.2; NIS2 Art.21; ISO 8.4.2	SOC productivity metrics

DOMINIO: CAPACITACIÓN (CAP)

ID	Pregunta	NIST CSF	ENS	NIS2	GDPR	ISO 27001	Artículos / Cláusulas	Evidencia Esperada
P9.1.1	¿Capacitación obligatoria anual >95%?	✓ PR-5	✓ C.5	✓ Art.24	✓ Art.32(2) (c)	✓ 8.3.2	NIST PR-5; ENS C.5; NIS2 Art.24; GDPR Art.32(2) (c); ISO 8.3.2	LMS report 2024/2025
P9.1.2	¿Contenido adaptado por rol?	✓ PR-6	✓ C.6	✓ Art.24	✓ Art.32(2) (c)	✓ 8.3.3	NIST PR-6; ENS C.6; NIS2 Art.24; GDPR Art.32(2) (c); ISO 8.3.3	Curriculum por rol (Dev, Admin, User)
P9.2.1	¿Simulacros phishing (mensual+)?	✓ PR-7	✓ C.7	✓ Art.24	✓ Art.32	✓ 8.3.4	NIST PR-7; ENS C.7; NIS2 Art.24; GDPR Art.32; ISO 8.3.4	Reports simulacros 2024/2025
P9.2.2	¿Phishing click rate <5% (target)?	✓ PR-8	✓ C.8	✓ Art.24	✓ Art.32	✓ 8.3.5	NIST PR-8; ENS C.8; NIS2 Art.24; GDPR Art.32; ISO 8.3.5	Metrics phishing platform
P9.3.1	¿Capacitación GDPR/Privacy (anual)?	✓ PR-9	✓ C.9	✓ Art.24	✓ Art.32(2)	✓ 8.3.6	NIST PR-9; ENS C.9; NIS2 Art.24; GDPR Art.32(2); ISO 8.3.6	Certificados privacy training

RESUMEN: COBERTURA NORMATIVA

Marco	Total Artículos	Preguntas Asociadas	Cobertura
NIST CSF 2.0	23 funciones	60+	100%
ENS	15 dimensiones	55+	100%
NIS2	24 artículos	50+	98%
GDPR	36 artículos relevantes	40+	95%
ISO 27001	114 cláusulas	55+	98%

Conclusión: Esta matriz demuestra que cada pregunta de la encuesta ACET contribuye explícitamente al cumplimiento de múltiples marcos normativos. Auditor regulador puede verificar trazabilidad completa pregunta → requisitos.